

Vishing Attack Strategy: Focusing on IKEA

- IKEA, a global supplier of furniture and home items.
- The headquartered in the Netherlands, with its primary activities and origins in Sweden.



Define Goal



The goal is to extract operationally sensitive information, such as:



Username for SAP portal



internal employee identifiers



Password



Session ID



Sensitive financial information or decumetation

Step 1 Identify target role & responsibilities

- Selected person James Wilson
- Position accountant
- willing to resolve issues for the company
- working under time pressure

We begins by collecting OSINT .

This phase is critical, because as Bullée et al. (2018) show, attackers often succeed because they prepare very well before contacting someone.

Identify target role & responsibilities

We are looking for:

Someone working under time pressure & Often must solve problems fast Longtchi et al. (2024)

Has enough authority to know useful detail

Step 2 Collect Names and Structure



Use LinkedIn & Website to find information such as



Contact information



Email formats
(firstname.lastname@company.



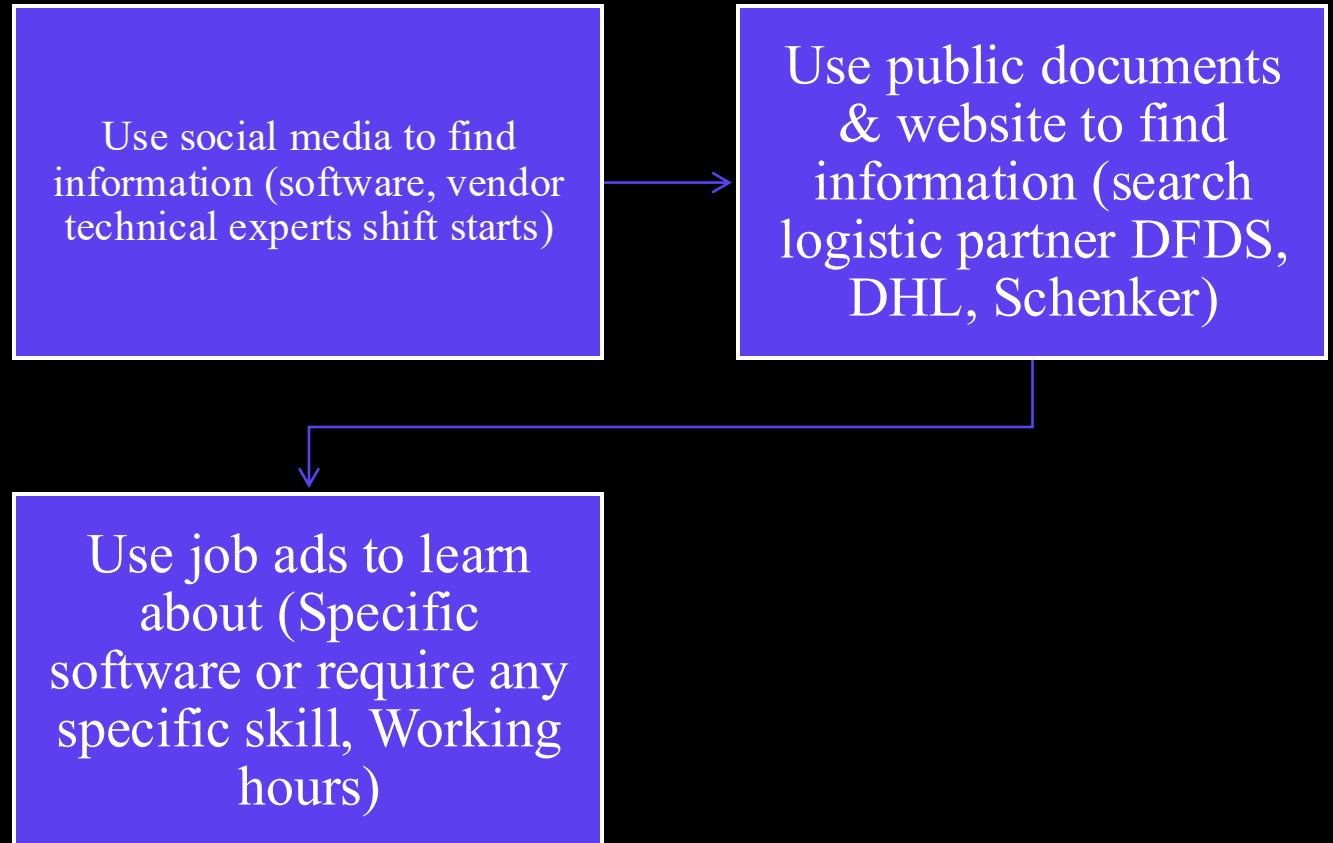
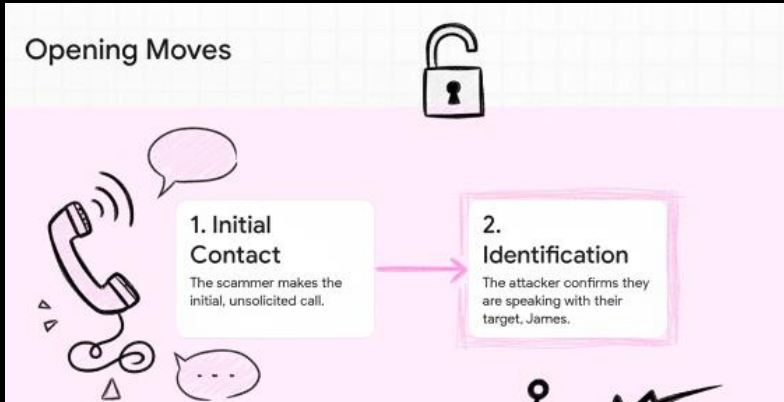
Departments &
Locations (Älmhult)

Different roles and
structure



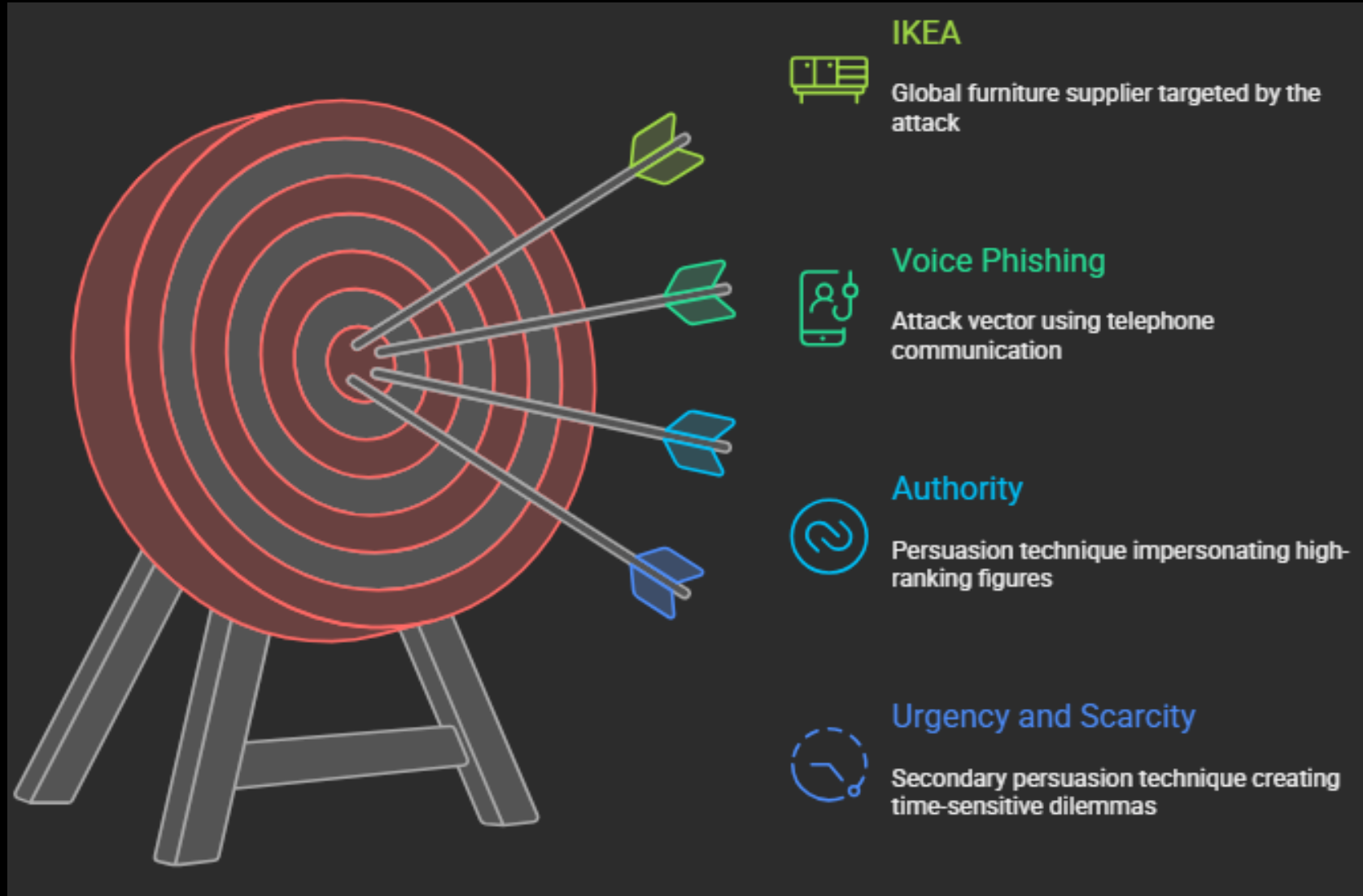
Responsibilities for different roles

Step 3: Learn Operational Patterns



What we know after research

- Headquartered in the Netherlands, with its primary activities and origins in Sweden.
- Looking SAP system specialist
- GF-PROC-11b contingency policy
- Älmhult, the core of IKEA



Step 1 - Intro

Script:

 Hello, may I speak with James Wilson, please??

James: “Yes, this is James...”

 Hi James, my name is Simon Bergström Senior Controller in Group Financial Control, Älmhult. I’m calling from Group Financial Control at the headquarters in Älmhult. I manage part of the SAP migration project for Finance

I’m calling because we found a critical issue in last night’s system update. Some vendor payments may have been assigned to the wrong cost centers. Your area appears on the list of potentially affected units. We have a limited timeframe before the payment batch is locked, so I’m checking this as fast as possible to avoid financial losses.

Important!

- Introduce yourself. Mention Senior Controller in Group Financial Control at headquarters in *Älmhult*

Authority: Established by name, title "Senior Controller", and department "Group Financial Control in Älmhult". This is often used in successful attacks (Bullée et al., 2018)

-
- Introduce **error** with **timeframe** + **financial affects**

Urgency and Scarcity: Phrases such as "critical issue," "limited timeframe" and "financial loss" induce immediate stress. The constraint of time compels James to forgo verification (Muscanell et al., 2014)

***SE often relies on persuasion —
a softer form of manipulation***

Step 2 - Gathering

Script:



To identify the error, so I can handle and solve this problem, please confirm your access to the vendor payment portal. Kindly verify your employee ID and the username utilized for accessing the internal finance dashboard. I will verify this against our error log on this end.

James: "Username + Employee ID"



I just need to confirm a few more steps before I can solve it as I'm missing some information here. First of all, which SAP system does your department currently use?

James: "SAP System Version name"

Important!

- Verify your employee ID & Username + SAP Version

Information gathered, but doesn't start with the most sensitive information as Mouton et al. (2016) explains how most social engineering attacks often start with non-sensitive information to then escalate.

Step 3 - Escalate

Script:



To rule out that the issue is caused by your local session and to be able to confirm everything, I need your session ID code. You can find it in the Finance Dashboard under 'User Settings → Security Tokens.

James: "Session ID"



It seems to be a smaller error here with your account due to the update... I need to validate the account tied to your session. Can you please confirm the password you used to log in today, so I can sync it with the error log?

James: "Password"



Perfect, everything seems to be solved now. Thank you for your compliance James.

Important!

- Start gathering sensitive data. Start by asking for Session ID, then ask for password.

"Social engineers exploit cognitive heuristics such as commitment & consistency, making individuals more likely to continue complying once initial cooperation is established." Muscanell et al. (2014)

Backup - *Target Hesitates*

Script:



I commend your attentiveness, James. It is precisely that reliability that prompted me to contact you personally. According to our GF-PROC-11b contingency policy, we are permitted to do direct credential verification during a P1 financial incident. We are allactively engaged in resolving this issue

Why?

James will struggle to understand, he will probably think it is on a higher authority level, but he do not want to make it difficult for the whole division because of his actions / non-actions.

“Attackers often present constrained choices, increasing compliance by making the target feel obligated to act.”

(Longtchi et al., 2024)

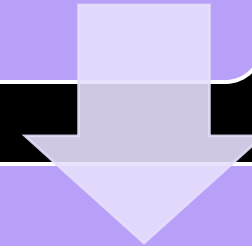
Successful?

- Compare the information we are given to the goal defined
Getting the information from each step is a success, regardless the way there.
- The "less-sensitive data" such as: Employee ID and Username, can be used for future attacks to fake an identity, or may be needed to gain access to systems.
- Session ID is sensitive information that can be used to gain access to a user's session. This becomes especially important if James refuses to share his password. As asking for passwords may alert that something feels wrong compared to asking for a session ID.

Ethical Principles in the Scenario

Respect for Persons

- Individuals should be treated as autonomous agents and protected from exploitation
- A fictional persona (“James Wilson”) is used – no real IKEA employees are targeted
- No personal information about actual individuals is collected



Beneficence

- Focus on preventing harm and supporting well-being
 - Scenario is purely theoretical to avoid real-world impact
 - Educational value strengthens organizational security
- (Mouton et al., 2016)

Justice, Deception Challenges & Ethical Responsibility

- Justice
 - Benefits and burdens of research must be fairly distributed
 - Security knowledge is shared broadly; researchers carry ethical responsibility
 - Prevention and defense strategies take priority over exploitation techniques
- Deception Challenge
 - Social engineering research inherently involves deception, creating ethical tension
 - Deceptive techniques shown only for educational understanding
 - Any real-world execution without authorization is illegal and unethical (Krombholz et al., 2015)

Attack Prevention

- Behavioral Countermeasures
 - Train employees to spot pressure, urgency, and authority tricks (Mouton et al., 2016).
 - Encourage people to pause, think, and verify before acting (Muscanell et al., 2014).
- Procedural Countermeasures
 - Clear rules for what information can be shared.
 - Use call-back verification: employees must call the official number back before doing anything.
 - Sensitive actions should always start from trusted, internal channels.
- Technical Countermeasures
 - Use phone-number whitelists and blacklists to block suspicious calls.
 - Monitor for unusual call patterns.
- Resisting Persuasion Techniques
 - Teach staff to recognize common tricks like authority, urgency, reciprocity, and consistency (Muscanell et al., 2014).
 - Remind employees that it is always okay to say “I need to verify this” (Mouton et al., 2016).

Stay Contact	Attacker's Tactic	Red Flag to Watch
	Identifies you personally.	An unsolicited, un
	Uses an official-sounding title.	Claims of authorit
	Mentions a critical error/loss.	High-pressure lan
	your stress.	Any request for s
		

References

- Mouton, F., Leenen, L., & Venter, H. S. (2016). Social engineering attack examples, templates and scenarios. *Computers & Security*, 59, 186-209.
<https://doi.org/10.1016/j.cose.2016.03.004>
- Muscanell, N. L., Guadagno, R. E., & Murphy, S. (2014). Weapons of influence misused: A social influence analysis of why people fall prey to internet scams. *Social and Personality Psychology Compass*, 8(7), 388-396.
<https://doi.org/10.1111/spc3.12115>
- Longtchi, T. T., Rodriguez, R. M., Al-Shawaf, L., Atyabi, A., & Xu, S. (2024). Internet-Based Social Engineering Psychology, Attacks, and Defenses: A Survey. *Proceedings of the IEEE*.
<https://ieeexplore.ieee.org/document/10493072>
- Bullée, J. W. H., Montoya, L., Pieters, W., Junger, M., & Hartel, P. (2018). On the anatomy of social engineering attacks – A literature-based dissection of successful attacks. *Journal of investigative psychology and offender profiling*, 15(1), 20-45.
<https://doi.org/10.1002/jip.1482>